

STPA analysis of Sistema Turistmo Inteligente

Sistema Turismo Inteligente

Begin date: 09/07/2025 21:09:32

Report created at: 29/08/2026 16:08:32

Step One - Purpose of the Analysis

Goals

G-1: Fornecer recomendações turísticas personalizadas baseadas em preferências e localização do usuário

G-2: Processar dados pessoais em total conformidade com a LGPD

G-3: Manter alta disponibilidade e confiabilidade do serviço

G-4: Proteger dados sensíveis inferidos de padrões de localização

G-5: Adotar minimização de dados e proteção desde a concepção em todas as fases do ciclo de vida

Assumptions

A-1: O controlador tem a boa fé de atender os requisitos legais da LGPD

A-2: O smartphone e o sistema de turismo inteligente já foram configurados

A-3: O turista mantém o smartphone e o serviço de GPS ativos

A-4: O sistema possui funcionalidade para verificar o consentimento de geolocalização

A-5: A rede móvel e a infraestrutura de GPS funcionam adequadamente

A-6: O sistema de banco de dados está ativo e opera corretamente

A-7: O turista compreende os termos de consentimento e está ciente de suas responsabilidades ao aceitá-los

A-8: Não há operador no sistema. O controlador realiza todo o tratamento de dados pessoais

A-9: Os usuários são adultos (maiores de 17 anos)

A-10: Nenhum dado pessoal é transmitido a serviços externos

Losses

L-1: Violação da privacidade de dados do turista

L-2: Perdas financeiras e de reputação decorrentes de ataques cibernéticos

L-3: Não cumprimento da missão de negócio

L-4: Não atendimento à LGPD

System-level Hazards

H-1: O sistema trata os dados pessoais sem base legal válida, para finalidades não declaradas ou sem a devida transparência com o titular [L-1] [L-2] [L-4]

H-2: O sistema não provê medidas técnicas e administrativas adequadas, permitindo acessos não autorizados, modificações indevidas, perda ou indisponibilidade dos dados pessoais [L-1] [L-2] [L-3] [L-4]

H-3: O sistema coleta dados excessivos, mantém dados incorretos ou desatualizados, retém além do necessário ou não exclui de forma segura após o término do tratamento [L-1] [L-2] [L-3] [L-4]

H-4: O sistema não provê mecanismos adequados para atender as solicitações de acesso, correção, eliminação, portabilidade ou oposição ao tratamento [L-1] [L-4]

H-5: O sistema utiliza dados pessoais, incluindo inferências sobre dados sensíveis, para perfilamento discriminatório ou decisões automatizadas que violem direitos do titular [L-1] [L-2] [L-4]

H-6: O sistema opera sem documentação adequada, logs auditáveis, processos de gestão de incidentes ou outras evidências necessárias para demonstrar conformidade com a LGPD [L-2] [L-4]

H-7: O sistema é incapaz de fornecer os serviços de forma satisfatória em termos de desempenho, utilidade e cibersegurança [L-3]

Systel-level Safety Constraints

SSC-1: O sistema deve prover mecanismos para o processamento de dados pessoais com finalidade declarada e de forma transparente para o titular [H-1]

SSC-2: O sistema deve dispor de mecanismos de cibersegurança para assegurar confidencialidade, integridade e disponibilidade [H-2]

SSC-3: O sistema deve gerenciar proativamente o ciclo de vida dos dados através de políticas automatizadas de minimização, validação de qualidade, retenção limitada e eliminação segura ou anonimização [H-3]

SSC-4: O sistema deve prover mecanismos amigáveis que permitam aos titulares exercer todos os seus direitos de forma simples e com resposta em prazos definidos [H-4]

SSC-5: O sistema deve dispor de mecanismos de detecção e correção de eventos que infirmem discriminação, incluindo auditoria de modelos e explicabilidade de decisões [H-5]

SSC-6: O sistema deve manter infraestrutura completa de governança incluindo documentação atualizada, logs imutáveis, processos de gestão de incidentes e evidências

auditáveis de conformidade [H-6]

SSC-7: O sistema deve dispor de mecanismos para prover os serviços de forma segura, efetiva e com desempenho adequado [H-7]

Step Two - Control Structure

Controller Turista

Responsibilities:

R-1: Gerir consentimentos e exercer direitos LGPD. [SSC-1] [SSC-4]

R-2: Fornecer dados e preferências atualizadas. [SSC-3]

R-3: Decidir sobre recomendações com base nas informações exibidas. [SSC-7]

R-4: Considerar condições/lotação/restrições locais sinalizadas. [SSC-7]

R-5: Seguir as políticas e recomendações de cibersegurança e privacidade de dados. [SSC-2]

R-6: Reportar incidentes/uso indevido pelos canais do app. [SSC-6]

Outgoing connections

Turista -> Smartphone do Turista

Control actions: Conceder consentimento de localização, Revogar consentimento de localização, Conceder consentimento de perfilamento, Revogar consentimento de perfilamento, Informar Dados Pessoais, Aceitar termos de consentimento, Solicitar confirmação da existência de tratamento, Solicitar acesso/relatório dos dados, Solicitar retificação/correção, Solicitar portabilidade, Solicitar anonimização, Solicitar informação sobre compartilhamento/transparência, Solicitar eliminação de dados tratados com consentimento, Solicitar bloqueio, Solicitar revisão de decisão automatizada/perfilamento, Solicitar eliminação de dados desnecessários/excessivos/desconformes

Turista -> Pontos Turísticos

Control actions: Utilizar

Incoming connections

Pontos Turísticos -> Turista

Feedbacks (variables and values):

Experiência turística (Ok, Não Ok)

Desejo Utilizar (Sim, Não)

Smartphone do Turista -> Turista

Feedbacks (variables and values):

Concessão de localização (Sim, DuranteUsoApp, Não)

Revogação de localização (Não, Sim)

Concessão de perfilamento (Sim, Não)

Revogação de perfilamento (Não, Sim)

Roteiro personalizado (Recebido, Não Recebido)

Alerta cibersegurança (Recebido, Não_recebido)

Alerta privacidade dados (Recebido, Não_recebido)

Direito LGPD (Nenhum, Em_processamento, Concluída, Negada, ErroTecnico)

Confirmacao Dados Pessoais (Pendente, Recebidos, Armazenados)

Status do aceite dos termos (Aceito, Negado, Pendente)

Controller Smartphone do Turista

Responsibilities:

R-1: Prover comunicação segura com o back-end. [SSC-2]

R-2: Gerenciar dados localmente com segurança e minimização. [SSC-2] [SSC-3]

R-3: Prover uma interface que permita uma interação amigável, apresentando informações e recomendações dos pontos turísticos e realçando questões relevantes de privacidade de dados. [SSC-7]

R-4: Exibir base legal, políticas de privacidade de dados/cibersegurança e status de consentimento. [SSC-1] [SSC-4] [SSC-6]

R-5: Exibir alertas de cibersegurança/privacidade de dados. [SSC-2] [SSC-6]

R-6: Solicitar atualização de dados com periodicidade adequada. [SSC-3] [SSC-7]

R-7: Apoiar a celebração do termo de consentimento: coletar a localização durante o uso do app. [SSC-1] [SSC-3] [SSC-4]

Outgoing connections

Smartphone do Turista -> Back-end (Servidor + Banco de Dados)

Control actions: Atualizar consentimento de localização, Atualizar consentimento de perfilamento, Enviar solicitação de roteiro, Encaminhar solicitação LGPD, Enviar Dados

Pessoais, Registrar aceite dos termos

Smartphone do Turista -> Turista

Incoming connections

Turista -> Smartphone do Turista

Back-end (Servidor + Banco de Dados) -> Smartphone do Turista

Feedbacks (variables and values):

Status de consentimento de localização (Ativo, Inativo)

Status de consentimento de perfilamento (Ativo, Inativo)

Roteiro Personalizado processado (Alto, Médio, Baixo, Nenhum)

Solicitação de reautenticação (Sim, Não)

Processamento LGPD (Ok, Não_Ok)

Localização considerada pelo sistema (Acomodação, Atual)

Status Dados Pessoais (Pendente, Recebidos, Armazenados, RecusadoLegal, ErroTecnico)

Termos de consentimento (versão) (VersãoAtual, Desatualizado)

Status aceite dos termos (Pendente, Aceito, Negado, ErroTecnico)

Controller Back-end (Servidor + Banco de Dados)

Responsibilities:

R-1: Processar dados com base legal, finalidade, transparência. [SSC-1]

R-2: Bloquear uso fora do escopo acordado. [SSC-1]

R-3: Aplicar minimização, retenção limitada e (pseudo) anonimização quando requerido e automatizar expurgo. [SSC-3]

R-4: Prover meios para atender direitos do titular com SLA e evidências (recibos/logs. [SSC-4] [SSC-6]

R-5: Detectar e prevenir processamento discriminatório. [SSC-5]

R-6: Dispor de controles de acesso e mecanismos de proteção de dados. [SSC-2]

R-7: Manter mecanismos de continuidade e recuperação (backup/restore testados): registrar logs imutáveis e trilhas auditáveis de conformidade. [SSC-6] [SSC-7]

R-8: Prover meios estruturados para auditorias de privacidade de dados. [SSC-6]

R-9: Manter modelo do processo (estado local e confiança da informação) e conciliar dados do SEFD. [SSC-6] [SSC-7]

Outgoing connections

Back-end (Servidor + Banco de Dados) -> SEFD

Control actions: Consultar clima, Solicitar localização do ponto turístico

Back-end (Servidor + Banco de Dados) -> Equipe de Operação

Back-end (Servidor + Banco de Dados) -> Smartphone do Turista

Back-end (Servidor + Banco de Dados) -> Pontos Turísticos

Control actions: Solicitar informações do ponto turístico periodicamente (dados, estado, nível, restrições)

Back-end (Servidor + Banco de Dados) -> Gerenciamento da empresa (Controlador, Encarregado)

Incoming connections

Smartphone do Turista -> Back-end (Servidor + Banco de Dados)

Feedbacks (variables and values):

Rastreabilidade de compartilhamento (Completa, Incompleta)

Qualidade da anonimização (Adequada, Inadequada)

Dados validados para portabilidade (Sim, Não)

Clausula de compartilhamento dados (Ok, Não Ok)

Elegibilidade para exercício do direito (Sim, Não)

SEFD -> Back-end (Servidor + Banco de Dados)

Feedbacks (variables and values):

Dados clima atual (Bom, Ruim)

Localização Ponto Turístico (Disponível, Indisponível)

Status conectividade API (Disponível, Indisponível, Degradado)

Equipe de Operação -> Back-end (Servidor + Banco de Dados)

Pontos Turísticos -> Back-end (Servidor + Banco de Dados)

Feedbacks (variables and values):

Dados do ponto turístico (identificação, horários, utilização) (Sim, Não, Normal, Alerta, Crítico)

Estado de operação do ponto turístico (Aberto, Restrito, Fechado)

Nível de ocupação do ponto turístico (Baixa, Média, Alta, Lotado)

Restrições locais (Nenhuma, Capacidade, Segurança, Clima)

Controller Gerenciamento da empresa (Controlador, Encarregado)

Responsibilities:

R-1: Estabelecer níveis de serviço e critérios de continuidade/risco. [SSC-2] [SSC-7]

R-2: Definir políticas e bases legais por finalidade. [SSC-1] [SSC-6]

R-3: Realizar relatório de impacto de proteção de dados quando aplicável. [SSC-1] [SSC-6]

R-4: Aprovar princípios de minimização/retenção e supervisionar execução. [SSC-3] [SSC-6]

R-5: Definir critérios de não discriminação e revisão humana. [SSC-5]

R-6: Coordenar resposta a incidentes com notificações à ANPD/titulares quando cabível. [SSC-2] [SSC-6]

R-7: Promover capacitação contínua em privacidade de dados e cibersegurança. [SSC-6]

R-8: Gerenciar terceiros/SEFD (contratos, cláusulas de proteção de dados, avaliação de risco). [SSC-2] [SSC-6]

Outgoing connections

Gerenciamento da empresa (Controlador, Encarregado) -> Equipe de Operação

Control actions: Definir diretrizes LGPD, Definir políticas de cibersegurança, Definir procedimentos de incidentes, Publicar termos de consentimento, Alocar recursos/treinamento, Determinar auditorias, Encaminhar pedidos LGPD dos titulares

Incoming connections

Equipe de Operação -> Gerenciamento da empresa (Controlador, Encarregado)

Feedbacks (variables and values):

Relatórios conformidade (auditorias, logs, incidentes, LGPD) (Conforme, Em_risco, Não_conforme)

Escalada incidentes graves (Recebido, Não Recebido)

Relatórios de incidentes e riscos (Baixo, Médio, Alto)

Status das solicitações LGPD (Atrasado, Concluído, Em_prazo)

Métricas operacionais (SLA, backlog, uso da equipe) (Adequada, Nao_Adequado)

Sugestões de melhoria (processos, recursos, ferramentas) (Recebida, Não_recebida)

Número das solicitações LGPD (Aceitável, Nao_Aceitavel)

Back-end (Servidor + Banco de Dados) -> Gerenciamento da empresa (Controlador, Encarregado)

Feedbacks (variables and values):

Dados automáticos de conformidade LGPD e governança de dados (relatórios, dashboards, métricas, notificações de violações graves) (Conforme, Em_risco, Não_conforme, Baixo, Médio, Alto, Aceitável, Nao_Aceitavel)

Controller Equipe de Operação

Responsibilities:

R-1: Monitorar disponibilidade, segurança e indicadores de privacidade de dados e cibersegurança. [SSC-2] [SSC-7]

R-2: Conter incidentes (isolar serviço, comandos de emergência) e coordenar recuperação. [SSC-2] [SSC-6] [SSC-7]

R-3: Gerenciar mudanças com processos bem estruturados de homologação e reversão. [SSC-4] [SSC-6]

R-4: Processar solicitações LGPD com registro, triagem, resposta e comprovação. [SSC-4] [SSC-6]

R-5: Realizar auditorias operacionais e revisar evidências. [SSC-6]

R-6: Operacionalizar políticas de retenção e eliminação segura de dados. [SSC-3] [SSC-6]

Outgoing connections

Equipe de Operação -> Back-end (Servidor + Banco de Dados)

Control actions: Habilitar registros de auditoria, Configurar controle de acesso e criptografia, Configurar retenção/eliminação de dados, Configurar anonimização/pseudonimização, Aplicar termos de consentimento, Habilitar monitoramento de incidentes, Processar solicitações LGPD, Conter incidentes, Comandar auditorias

Equipe de Operação -> Gerenciamento da empresa (Controlador, Encarregado)

Incoming connections

Back-end (Servidor + Banco de Dados) -> Equipe de Operação

Feedbacks (variables and values):

Status de execução de controles (logs, acesso/criptografia, retenção,anonimização, monitoramento, termos de consentimento) (Executado, Pendente, Falha)

Relatórios solicitações LGPD (registro,andamento, conclusão de pedidos) (Em_prazo, Atrasado, Concluído)

Logs LGPD/Cibersegurança (acessos, eventos de segurança, trilhas de auditoria) (Disponível, Indisponível)

Alertas críticos (incidentes, falhas graves, violações de segurança/privacidade) (Recebido, Não_recebido)

Relatórios operacionais (disponibilidade, desempenho, backup, serviços externos) (Normal, Inoperante, Degradado)

Gerenciamento da empresa (Controlador, Encarregado) -> Equipe de Operação

External System SEFD

Outgoing connections

SEFD -> Back-end (Servidor + Banco de Dados)

Incoming connections

Back-end (Servidor + Banco de Dados) -> SEFD

Controlled Process Pontos Turisticos

Outgoing connections

Pontos Turisticos -> Back-end (Servidor + Banco de Dados)

Pontos Turisticos -> Turista

Incoming connections

Back-end (Servidor + Banco de Dados) -> Pontos Turisticos

Turista -> Pontos Turisticos

Environmental Disturbances: Chuvas, Interdições Locais

Step Three - Unsafe Control Actions

Unsafe Control Actions (UCA) and Safety Constraints (SC)

Recommendation 1: (Controller: Back-end (Servidor + Banco de Dados) - Control Action: Consultar clima)

UCA-1: Back-end (Servidor + Banco de Dados) not provided Consultar clima when Status conectividade API is Disponível. [H-7]

Description:

SC-1: Back-end (Servidor + Banco de Dados) shall provide Consultar clima when Status conectividade API is Disponível.

Recommendation 2: (Controller: Back-end (Servidor + Banco de Dados) - Control Action: Consultar clima)

UCA-2: Back-end (Servidor + Banco de Dados) provided Consultar clima when Status conectividade API is Indisponível. [H-7]

Description:

SC-2: Back-end (Servidor + Banco de Dados) shall not provide Consultar clima when Status conectividade API is Indisponível.

Recommendation 3: (Controller: Back-end (Servidor + Banco de Dados) - Control Action: Consultar clima)

UCA-3: Back-end (Servidor + Banco de Dados) provided Consultar clima when Status conectividade API is Degradado. [H-7]

Description:

SC-3: Back-end (Servidor + Banco de Dados) shall not provide Consultar clima when Status conectividade API is Degradado.

Recommendation 4: (Controller: Back-end (Servidor + Banco de Dados) - Control Action: Solicitar localização do ponto turístico)

UCA-4: Back-end (Servidor + Banco de Dados) not provided Solicitar localização do ponto turístico when Localização Ponto Turístico is Indisponível, Status conectividade API is Disponível. [H-7]

Description:

SC-4: Back-end (Servidor + Banco de Dados) shall provide Solicitar localização do ponto turístico when Localização Ponto Turístico is Indisponível, Status conectividade API is

Disponível.

Recommendation 5: (Controller: Back-end (Servidor + Banco de Dados) - Control Action: Solicitar localização do ponto turístico)

UCA-5: Back-end (Servidor + Banco de Dados) provided Solicitar localização do ponto turístico when Status conectividade API is Indisponível. [H-7]

Description:

SC-5: Back-end (Servidor + Banco de Dados) shall not provide Solicitar localização do ponto turístico when Status conectividade API is Indisponível.

Recommendation 6: (Controller: Back-end (Servidor + Banco de Dados) - Control Action: Solicitar localização do ponto turístico)

UCA-6: Back-end (Servidor + Banco de Dados) provided Solicitar localização do ponto turístico when Status conectividade API is Degradado. [H-7]

Description:

SC-6: Back-end (Servidor + Banco de Dados) shall not provide Solicitar localização do ponto turístico when Status conectividade API is Degradado.

Recommendation 7: (Controller: Back-end (Servidor + Banco de Dados) - Control Action: Solicitar informações do ponto turístico periodicamente (dados, estado, nível, restrições))

UCA-7: Back-end (Servidor + Banco de Dados) not provided Solicitar informações do ponto turístico periodicamente (dados, estado, nível, restrições) when Dados do ponto turístico (identificação, horários, utilização) is Não. [H-7]

Description:

SC-7: Back-end (Servidor + Banco de Dados) shall provide Solicitar informações do ponto turístico periodicamente (dados, estado, nível, restrições) when Dados do ponto turístico (identificação, horários, utilização) is Não.

Recommendation 8: (Controller: Back-end (Servidor + Banco de Dados) - Control Action: Solicitar informações do ponto turístico periodicamente (dados, estado, nível, restrições))

UCA-8: Back-end (Servidor + Banco de Dados) not provided Solicitar informações do ponto turístico periodicamente (dados, estado, nível, restrições) when Estado de operação do ponto turístico is Restrito. [H-7]

Description:

SC-8: Back-end (Servidor + Banco de Dados) shall provide Solicitar informações do ponto turístico periodicamente (dados, estado, nível, restrições) when Estado de operação do ponto turístico is Restrito.

Recommendation 9: (Controller: Back-end (Servidor + Banco de Dados) - Control Action: Solicitar informações do pontoturístico periodicamente (dados,estado, nível, restrições))

UCA-9: Back-end (Servidor + Banco de Dados) not provided Solicitar informações do pontoturístico periodicamente (dados,estado, nível, restrições) when Nível de ocupação do ponto turístico is Lotado. [H-7]

Description:

SC-9: Back-end (Servidor + Banco de Dados) shall provide Solicitar informações do pontoturístico periodicamente (dados,estado, nível, restrições) when Nível de ocupação do ponto turístico is Lotado.

Recommendation 10: (Controller: Back-end (Servidor + Banco de Dados) - Control Action: Solicitar informações do pontoturístico periodicamente (dados,estado, nível, restrições))

UCA-10: Back-end (Servidor + Banco de Dados) not provided Solicitar informações do pontoturístico periodicamente (dados,estado, nível, restrições) when Restrições locais is Segurança. [H-7]

Description:

SC-10: Back-end (Servidor + Banco de Dados) shall provide Solicitar informações do pontoturístico periodicamente (dados,estado, nível, restrições) when Restrições locais is Segurança.

Recommendation 11: (Controller: Back-end (Servidor + Banco de Dados) - Control Action: Solicitar informações do pontoturístico periodicamente (dados,estado, nível, restrições))

UCA-11: Back-end (Servidor + Banco de Dados) not provided Solicitar informações do pontoturístico periodicamente (dados,estado, nível, restrições) when Restrições locais is Clima. [H-7]

Description:

SC-11: Back-end (Servidor + Banco de Dados) shall provide Solicitar informações do pontoturístico periodicamente (dados,estado, nível, restrições) when Restrições locais is Clima.

Recommendation 12: (Controller: Equipe de Operação - Control Action: Habilitar registros de auditoria)

UCA-12: Equipe de Operação not provided Habilitar registros de auditoria when Logs LGPD/Cibersegurança (acessos, eventos de segurança, trilhas de auditoria) is Indisponível. [H-6]

Description:

SC-12: Equipe de Operação shall provide Habilitar registros de auditoria when Logs LGPD/Cibersegurança (acessos, eventos de segurança, trilhas de auditoria) is Indisponível.

Recommendation 13: (Controller: Equipe de Operação - Control Action: Configurar controle de acesso e criptografia)

UCA-13: Equipe de Operação not provided Configurar controle de acesso e criptografia when Alertas críticos (incidentes, falhas graves, violações de segurança/privacidade) is Recebido. [H-2]

Description:

SC-13: Equipe de Operação shall provide Configurar controle de acesso e criptografia when Alertas críticos (incidentes, falhas graves, violações de segurança/privacidade) is Recebido.

Recommendation 14: (Controller: Equipe de Operação - Control Action: Configurar controle de acesso e criptografia)

UCA-14: Equipe de Operação not provided Configurar controle de acesso e criptografia when Status de execução de controles (logs, acesso/criptografia, retenção,anonimização, monitoramento, termos de consentimento) is Falha. [H-2]

Description:

SC-14: Equipe de Operação shall provide Configurar controle de acesso e criptografia when Status de execução de controles (logs, acesso/criptografia, retenção,anonimização, monitoramento, termos de consentimento) is Falha.

Recommendation 15: (Controller: Equipe de Operação - Control Action: Configurar retenção/eliminação de dados)

UCA-15: Equipe de Operação not provided Configurar retenção/eliminação de dados when Relatórios solicitações LGPD (registro,andamento, conclusão de pedidos) is Atrasado. [H-3][H-4]

Description:

SC-15: Equipe de Operação shall provide Configurar retenção/eliminação de dados when Relatórios solicitações LGPD (registro,andamento, conclusão de pedidos) is Atrasado.

Recommendation 16: (Controller: Equipe de Operação - Control Action: Configurar retenção/eliminação de dados)

UCA-16: Equipe de Operação not provided Configurar retenção/eliminação de dados when Status de execução de controles (logs, acesso/criptografia, retenção,anonimização, monitoramento, termos de consentimento) is Falha. [H-3]

Description:

SC-16: Equipe de Operação shall provide Configurar retenção/eliminação de dados when Status de execução de controles (logs, acesso/criptografia, retenção,anonimização, monitoramento, termos de consentimento) is Falha.

Recommendation 17: (Controller: Equipe de Operação - Control Action: Configurar anonimização/pseudonimização)

UCA-17: Equipe de Operação not provided Configurar anonimização/pseudonimização when Status de execução de controles (logs, acesso/criptografia, retenção,anonimização, monitoramento, termos de consentimento) is Falha. [H-3][H-5]

Description:

SC-17: Equipe de Operação shall provide Configurar anonimização/pseudonimização when Status de execução de controles (logs, acesso/criptografia, retenção,anonimização, monitoramento, termos de consentimento) is Falha.

Recommendation 18: (Controller: Equipe de Operação - Control Action: Aplicar termos de consentimento)

UCA-18: Equipe de Operação not provided Aplicar termos de consentimento when Status de execução de controles (logs, acesso/criptografia, retenção,anonimização, monitoramento, termos de consentimento) is Falha. [H-1][H-6]

Description:

SC-18: Equipe de Operação shall provide Aplicar termos de consentimento when Status de execução de controles (logs, acesso/criptografia, retenção,anonimização, monitoramento, termos de consentimento) is Falha.

Recommendation 19: (Controller: Equipe de Operação - Control Action: Habilitar monitoramento de incidentes)

UCA-19: Equipe de Operação not provided Habilitar monitoramento de incidentes when Relatórios operacionais (disponibilidade, desempenho, backup, serviços externos) is Inoperante. [H-2][H-6]

Description:

SC-19: Equipe de Operação shall provide Habilitar monitoramento de incidentes when Relatórios operacionais (disponibilidade, desempenho, backup, serviços externos) is Inoperante.

Recommendation 20: (Controller: Equipe de Operação - Control Action: Processar solicitações LGPD)

UCA-20: Equipe de Operação not provided Processar solicitações LGPD when Relatórios solicitações LGPD (registro,andamento, conclusão de pedidos) is Atrasado. [H-4]

Description:

SC-20: Equipe de Operação shall provide Processar solicitações LGPD when Relatórios solicitações LGPD (registro, andamento, conclusão de pedidos) is Atrasado.

Recommendation 21: (Controller: Equipe de Operação - Control Action: Conter incidentes)

UCA-21: Equipe de Operação not provided Conter incidentes when Alertas críticos (incidentes, falhas graves, violações de segurança/privacidade) is Recebido. [H-2][H-6]

Description:

SC-21: Equipe de Operação shall provide Conter incidentes when Alertas críticos (incidentes, falhas graves, violações de segurança/privacidade) is Recebido.

Recommendation 22: (Controller: Equipe de Operação - Control Action: Comandar auditorias)

UCA-22: Equipe de Operação not provided Comandar auditorias when Alertas críticos (incidentes, falhas graves, violações de segurança/privacidade) is Recebido. [H-6]

Description:

SC-22: Equipe de Operação shall provide Comandar auditorias when Alertas críticos (incidentes, falhas graves, violações de segurança/privacidade) is Recebido.

Recommendation 23: (Controller: Gerenciamento da empresa (Controlador, Encarregado) - Control Action: Definir diretrizes LGPD)

UCA-23: Gerenciamento da empresa (Controlador, Encarregado) not provided Definir diretrizes LGPD when Relatórios conformidade (auditorias, logs, incidentes, LGPD) is Não_conforme. [H-1][H-6]

Description:

SC-23: Gerenciamento da empresa (Controlador, Encarregado) shall provide Definir diretrizes LGPD when Relatórios conformidade (auditorias, logs, incidentes, LGPD) is Não_conforme.

Recommendation 24: (Controller: Gerenciamento da empresa (Controlador, Encarregado) - Control Action: Definir políticas de cibersegurança)

UCA-24: Gerenciamento da empresa (Controlador, Encarregado) not provided Definir políticas de cibersegurança when Escalada incidentes graves is Recebido. [H-2]

Description:

SC-24: Gerenciamento da empresa (Controlador, Encarregado) shall provide Definir políticas de cibersegurança when Escalada incidentes graves is Recebido.

Recommendation 25: (Controller: Gerenciamento da empresa (Controlador, Encarregado) - Control Action: Definir procedimentos de incidentes)

UCA-25: Gerenciamento da empresa (Controlador, Encarregado) not provided Definir procedimentos de incidentes when Escalada incidentes graves is Recebido. [H-2][H-6]

Description:

SC-25: Gerenciamento da empresa (Controlador, Encarregado) shall provide Definir procedimentos de incidentes when Escalada incidentes graves is Recebido.

Recommendation 26: (Controller: Gerenciamento da empresa (Controlador, Encarregado) - Control Action: Publicar termos de consentimento)

UCA-26: Gerenciamento da empresa (Controlador, Encarregado) not provided Publicar termos de consentimento when Relatórios conformidade (auditorias,logs, incidentes, LGPD) is Não_conforme. [H-1][H-6]

Description:

SC-26: Gerenciamento da empresa (Controlador, Encarregado) shall provide Publicar termos de consentimento when Relatórios conformidade (auditorias,logs, incidentes, LGPD) is Não_conforme.

Recommendation 27: (Controller: Gerenciamento da empresa (Controlador, Encarregado) - Control Action: Alocar recursos/treinamento)

UCA-27: Gerenciamento da empresa (Controlador, Encarregado) not provided Alocar recursos/treinamento when Status das solicitações LGPD is Atrasado. [H-4][H-7]

Description:

SC-27: Gerenciamento da empresa (Controlador, Encarregado) shall provide Alocar recursos/treinamento when Status das solicitações LGPD is Atrasado.

Recommendation 28: (Controller: Gerenciamento da empresa (Controlador, Encarregado) - Control Action: Determinar auditorias)

UCA-28: Gerenciamento da empresa (Controlador, Encarregado) not provided Determinar auditorias when Relatórios conformidade (auditorias,logs, incidentes, LGPD) is Não_conforme. [H-6]

Description:

SC-28: Gerenciamento da empresa (Controlador, Encarregado) shall provide Determinar auditorias when Relatórios conformidade (auditorias,logs, incidentes, LGPD) is

Não_conforme.

Recommendation 29: (Controller: Gerenciamento da empresa (Controlador, Encarregado) - Control Action: Encaminhar pedidos LGPD dos titulares)

UCA-29: Gerenciamento da empresa (Controlador, Encarregado) not provided Encaminhar pedidos LGPD dos titulares when Status das solicitações LGPD is Atrasado. [H-4]

Description:

SC-29: Gerenciamento da empresa (Controlador, Encarregado) shall provide Encaminhar pedidos LGPD dos titulares when Status das solicitações LGPD is Atrasado.

Recommendation 30: (Controller: Smartphone do Turista - Control Action: Enviar Dados Pessoais)

UCA-30: Smartphone do Turista provided Enviar Dados Pessoais when Status aceite dos termos is Negado. [H-1]

Description:

SC-30: Smartphone do Turista shall not provide Enviar Dados Pessoais when Status aceite dos termos is Negado.

Recommendation 31: (Controller: Smartphone do Turista - Control Action: Enviar solicitação de roteiro)

UCA-31: Smartphone do Turista provided Enviar solicitação de roteiro when Status aceite dos termos is Negado. [H-1]

Description:

SC-31: Smartphone do Turista shall not provide Enviar solicitação de roteiro when Status aceite dos termos is Negado.

Recommendation 32: (Controller: Smartphone do Turista - Control Action: Registrar aceite dos termos)

UCA-32: Smartphone do Turista provided in wrong order Registrar aceite dos termos when Status Dados Pessoais is Armazenados. [H-1][H-6]

Description:

SC-32: Smartphone do Turista shall not provide in wrong order Registrar aceite dos termos when Status Dados Pessoais is Armazenados.

Recommendation 33: (Controller: Smartphone do Turista - Control Action: Registrar aceite dos termos)

UCA-33: Smartphone do Turista provided Registrar aceite dos termos when Termos de consentimento (versão) is Desatualizado. [H-1][H-6]

Description:

SC-33: Smartphone do Turista shall not provide Registrar aceite dos termos when Termos de consentimento (versão) is Desatualizado.

Recommendation 34: (Controller: Smartphone do Turista - Control Action: Atualizar consentimento de localização)

UCA-34: Smartphone do Turista provided Atualizar consentimento de localização when Status aceite dos termos is Negado. [H-1]

Description:

SC-34: Smartphone do Turista shall not provide Atualizar consentimento de localização when Status aceite dos termos is Negado.

Recommendation 35: (Controller: Smartphone do Turista - Control Action: Atualizar consentimento de localização)

UCA-35: Smartphone do Turista provided Atualizar consentimento de localização when Termos de consentimento (versão) is Desatualizado. [H-1][H-6]

Description:

SC-35: Smartphone do Turista shall not provide Atualizar consentimento de localização when Termos de consentimento (versão) is Desatualizado.

Recommendation 36: (Controller: Smartphone do Turista - Control Action: Atualizar consentimento de localização)

UCA-36: Smartphone do Turista provided Atualizar consentimento de localização when Solicitação de reautenticação is Sim. [H-2]

Description:

SC-36: Smartphone do Turista shall not provide Atualizar consentimento de localização when Solicitação de reautenticação is Sim.

Recommendation 37: (Controller: Smartphone do Turista - Control Action: Atualizar consentimento de perfilamento)

UCA-37: Smartphone do Turista provided Atualizar consentimento de perfilamento when Status aceite dos termos is Negado. [H-1][H-5]

Description:

SC-37: Smartphone do Turista shall not provide Atualizar consentimento de perfilamento when Status aceite dos termos is Negado.

Recommendation 38: (Controller: Smartphone do Turista - Control Action: Atualizar consentimento de perfilamento)

UCA-38: Smartphone do Turista provided Atualizar consentimento de perfilamento when Termos de consentimento (versão) is Desatualizado. [H-1][H-5][H-6]

Description:

SC-38: Smartphone do Turista shall not provide Atualizar consentimento de perfilamento when Termos de consentimento (versão) is Desatualizado.

Recommendation 39: (Controller: Smartphone do Turista - Control Action: Atualizar consentimento de perfilamento)

UCA-39: Smartphone do Turista provided Atualizar consentimento de perfilamento when Solicitação de reautenticação is Sim. [H-5][H-2]

Description:

SC-39: Smartphone do Turista shall not provide Atualizar consentimento de perfilamento when Solicitação de reautenticação is Sim.

Recommendation 40: (Controller: Smartphone do Turista - Control Action: Enviar Dados Pessoais)

UCA-40: Smartphone do Turista provided Enviar Dados Pessoais when Termos de consentimento (versão) is Desatualizado. [H-1][H-6]

Description:

SC-40: Smartphone do Turista shall not provide Enviar Dados Pessoais when Termos de consentimento (versão) is Desatualizado.

Recommendation 41: (Controller: Smartphone do Turista - Control Action: Enviar Dados Pessoais)

UCA-41: Smartphone do Turista provided Enviar Dados Pessoais when Solicitação de reautenticação is Sim. [H-2]

Description:

SC-41: Smartphone do Turista shall not provide Enviar Dados Pessoais when Solicitação de reautenticação is Sim.

Recommendation 42: (Controller: Smartphone do Turista - Control Action: Enviar Dados Pessoais)

UCA-42: Smartphone do Turista provided Enviar Dados Pessoais when Solicitação de reautenticação is Sim, Status Dados Pessoais is RecusadoLegal. [H-1][H-3]

Description:

SC-42: Smartphone do Turista shall not provide Enviar Dados Pessoais when Solicitação de reautenticação is Sim, Status Dados Pessoais is RecusadoLegal.

Recommendation 43: (Controller: Smartphone do Turista - Control Action: Enviar solicitação de roteiro)

UCA-43: Smartphone do Turista provided Enviar solicitação de roteiro when Solicitação de reautenticação is Sim. [H-2]

Description:

SC-43: Smartphone do Turista shall not provide Enviar solicitação de roteiro when Solicitação de reautenticação is Sim.

Recommendation 44: (Controller: Smartphone do Turista - Control Action: Enviar solicitação de roteiro)

UCA-44: Smartphone do Turista provided Enviar solicitação de roteiro when Status Dados Pessoais is RecusadoLegal. [H-1][H-7]

Description:

SC-44: Smartphone do Turista shall not provide Enviar solicitação de roteiro when Status Dados Pessoais is RecusadoLegal.

Recommendation 45: (Controller: Smartphone do Turista - Control Action: Enviar solicitação de roteiro)

UCA-45: Smartphone do Turista not provided Enviar solicitação de roteiro when Status Dados Pessoais is Armazenados, Status aceite dos termos is Aceito. [H-1][H-7]

Description:

SC-45: Smartphone do Turista shall provide Enviar solicitação de roteiro when Status Dados Pessoais is Armazenados, Status aceite dos termos is Aceito.

Recommendation 46: (Controller: Smartphone do Turista - Control Action: Encaminhar solicitação LGPD)

UCA-46: Smartphone do Turista provided Encaminhar solicitação LGPD when Solicitação de reautenticação is Sim. [H-2]

Description:

SC-46: Smartphone do Turista shall not provide Encaminhar solicitação LGPD when Solicitação de reautenticação is Sim.

Recommendation 47: (Controller: Smartphone do Turista - Control Action: Encaminhar solicitação LGPD)

UCA-47: Smartphone do Turista not provided Encaminhar solicitação LGPD when Processamento LGPD is Não_Ok. [H-4]

Description:

SC-47: Smartphone do Turista shall provide Encaminhar solicitação LGPD when Processamento LGPD is Não_Ok.

Recommendation 48: (Controller: Smartphone do Turista - Control Action: Registrar aceite dos termos)

UCA-48: Smartphone do Turista provided Registrar aceite dos termos when Solicitação de reautenticação is Sim. [H-2][H-6]

Description:

SC-48: Smartphone do Turista shall not provide Registrar aceite dos termos when Solicitação de reautenticação is Sim.

Recommendation 49: (Controller: Smartphone do Turista - Control Action: Registrar aceite dos termos)

UCA-49: Smartphone do Turista not provided Registrar aceite dos termos when Status aceite dos termos is ErroTecnico. [H-1][H-6][H-7]

Description:

SC-49: Smartphone do Turista shall provide Registrar aceite dos termos when Status aceite dos termos is ErroTecnico.

Recommendation 50: (Controller: Turista - Control Action: Conceder consentimento de localização)

UCA-50: Turista provided Conceder consentimento de localização when Status do aceite dos termos is Pendente. [H-1]

Description:

SC-50: Turista shall not provide Conceder consentimento de localização when Status do aceite dos termos is Pendente.

Recommendation 51: (Controller: Turista - Control Action: Conceder consentimento de localização)

UCA-51: Turista provided Conceder consentimento de localização when Status do aceite dos termos is Negado. [H-1]

Description:

SC-51: Turista shall not provide Conceder consentimento de localização when Status do aceite dos termos is Negado.

Recommendation 52: (Controller: Turista - Control Action: Conceder consentimento de perfilamento)

UCA-52: Turista provided Conceder consentimento de perfilamento when Status do aceite dos termos is Pendente. [H-5][H-1]

Description:

SC-52: Turista shall not provide Conceder consentimento de perfilamento when Status do aceite dos termos is Pendente.

Recommendation 53: (Controller: Turista - Control Action: Conceder consentimento de perfilamento)

UCA-53: Turista provided Conceder consentimento de perfilamento when Status do aceite dos termos is Negado. [H-5]

Description:

SC-53: Turista shall not provide Conceder consentimento de perfilamento when Status do aceite dos termos is Negado.

Recommendation 54: (Controller: Turista - Control Action: Informar Dados Pessoais)

UCA-54: Turista provided Informar Dados Pessoais when Status do aceite dos termos is Pendente. [H-1]

Description: informar dados sem termos aceitos → tratamento sem base/sem transparência

SC-54: Turista shall not provide Informar Dados Pessoais when Status do aceite dos termos is Pendente.

Recommendation 55: (Controller: Turista - Control Action: Informar Dados Pessoais)

UCA-55: Turista provided Informar Dados Pessoais when Status do aceite dos termos is Negado. [H-1]

Description: informar dados após negar → sem base legal

SC-55: Turista shall not provide Informar Dados Pessoais when Status do aceite dos termos is Negado.

Recommendation 56: (Controller: Turista - Control Action: Utilizar)

UCA-56: Turista provided Utilizar when Status do aceite dos termos is Negado. [H-1]

Description: o turista usa após negar → inconsistência de base legal

SC-56: Turista shall not provide Utilizar when Status do aceite dos termos is Negado.

Recommendation 57: (Controller: Turista - Control Action: Utilizar)

UCA-57: Turista provided Utilizar when Status do aceite dos termos is Pendente. [H-1]

Description: o turista tenta usar o serviço sem termos aceitos → tratamento/uso sem base/sem transparência

SC-57: Turista shall not provide Utilizar when Status do aceite dos termos is Pendente.

Recommendation 58: (Controller: Turista - Control Action: Conceder consentimento de localização)

UCA-58: Turista not provided Conceder consentimento de localização when Desejo Utilizar is Sim. [H-7]

Description:

SC-58: Turista shall provide Conceder consentimento de localização when Desejo Utilizar is Sim.

Recommendation 59: (Controller: Turista - Control Action: Revogar consentimento de localização)

UCA-59: Turista not provided Revogar consentimento de localização when Desejo Utilizar is Não. [H-5]

Description:

SC-59: Turista shall provide Revogar consentimento de localização when Desejo Utilizar is Não.

Recommendation 60: (Controller: Turista - Control Action: Revogar consentimento de localização)

UCA-60: Turista provided Revogar consentimento de localização when Desejo Utilizar is Sim. [H-7]

Description:

SC-60: Turista shall not provide Revogar consentimento de localização when Desejo Utilizar is Sim.

Recommendation 61: (Controller: Turista - Control Action: Conceder consentimento de perfilamento)

UCA-61: Turista not provided Conceder consentimento de perfilamento when Desejo Utilizar is Sim. [H-7]

Description:

SC-61: Turista shall provide Conceder consentimento de perfilamento when Desejo Utilizar is Sim.

Recommendation 62: (Controller: Turista - Control Action: Revogar consentimento de perfilamento)

UCA-62: Turista not provided Revogar consentimento de perfilamento when Desejo Utilizar is Não. [H-5]

Description:

SC-62: Turista shall provide Revogar consentimento de perfilamento when Desejo Utilizar is Não.

Recommendation 63: (Controller: Turista - Control Action: Revogar consentimento de perfilamento)

UCA-63: Turista provided Revogar consentimento de perfilamento when Desejo Utilizar is Sim. [H-7]

Description:

SC-63: Turista shall not provide Revogar consentimento de perfilamento when Desejo Utilizar is Sim.

Recommendation 64: (Controller: Turista - Control Action: Aceitar termos de consentimento)

UCA-64: Turista not provided Aceitar termos de consentimento when Desejo Utilizar is Sim. [H-7]

Description: ele quer usar, mas não aceita termos → o sistema não pode operar corretamente (legalmente/funcionalmente)

SC-64: Turista shall provide Aceitar termos de consentimento when Desejo Utilizar is Sim.

Recommendation 65: (Controller: Turista - Control Action: Solicitar bloqueio)

UCA-65: Turista provided Solicitar bloqueio when Desejo Utilizar is Sim. [H-7]

Description: bloquear dado necessário enquanto quer usar degrada serviço

SC-65: Turista shall not provide Solicitar bloqueio when Desejo Utilizar is Sim.

Recommendation 66: (Controller: Turista - Control Action: Solicitar eliminação de dados desnecessários/excessivos/desconformes)

UCA-66: Turista provided Solicitar eliminação de dados desnecessários/excessivos/desconformes when Desejo Utilizar is Sim. [H-7]

Description: eliminar dado necessário ao processamento enquanto quer usar degrada serviço

SC-66: Turista shall not provide Solicitar eliminação de dados desnecessários/excessivos/desconformes when Desejo Utilizar is Sim.

Recommendation 67: (Controller: Turista - Control Action: Solicitar eliminação de dados tratados com consentimento)

UCA-67: Turista provided Solicitar eliminação de dados tratados com consentimento when Confirmacao Dados Pessoais is Armazenados, Desejo Utilizar is Sim. [H-7]

Description: excluir dados necessários durante uso degrada serviço

SC-67: Turista shall not provide Solicitar eliminação de dados tratados com consentimento when Confirmacao Dados Pessoais is Armazenados, Desejo Utilizar is Sim.

Recommendation 68: (Controller: Turista - Control Action: Aceitar termos de consentimento)

UCA-68: Turista provided in wrong order Aceitar termos de consentimento when Confirmacao Dados Pessoais is Recebidos. [H-1][H-6]

Description:

SC-68: Turista shall not provide in wrong order Aceitar termos de consentimento when Confirmacao Dados Pessoais is Recebidos.

Recommendation 69: (Controller: Turista - Control Action: Informar Dados Pessoais)

UCA-69: Turista not provided Informar Dados Pessoais when Status do aceite dos termos is Aceito, Desejo Utilizar is Sim. [H-7]

Description:

SC-69: Turista shall provide Informar Dados Pessoais when Status do aceite dos termos is Aceito, Desejo Utilizar is Sim.

Step Four - Loss Scenarios and Recommendations

R-1 (Turista Algorithm/Logic in Turista): UCA-64

Type: Unsafe controller behavior

Cause: A ANPD não promoveu, no ambiente regulatório, conscientização suficiente do titular sobre seus direitos LGPD, reduzindo a base de conhecimento com que o titular interage com o sistema.

Recommendation: A ANPD deve educar os titulares dos dados pessoais promovendo campanhas efetivas de conscientização sobre a lei e os direitos e deveres do titular.

Mechanism: Campanha em televisão e rádio, com comunicação sobre perfilamento, geolocalização e direitos do titular.

R-2 (Turista Process Model in Turista): UCA-50

Type: Unsafe controller behavior

Cause: O titular não compreende, no momento da ação, que conceder consentimento específico de localização ou perfilamento, ou informar dados pessoais, antes do aceite dos termos gerais, configura tratamento sem base legal válida.

Recommendation: O sistema deve impedir, no fluxo de uso, a emissão pelo titular de ações de consentimento específico ou de fornecimento de dados pessoais enquanto os termos de consentimento não estiverem aceitos.

Mechanism: Bloqueio, na interface, dos campos de consentimento de localização e perfilamento e dos formulários de dados pessoais até que o status do aceite dos termos esteja como Aceito, com orientação visual explícita ao titular sobre a sequência exigida.

R-3 (Turista Process Model in Turista): UCA-56

Type: Unsafe controller behavior

Cause: O titular não compreende, no momento da ação, que utilizar o sistema antes do aceite dos termos implica tratamento sem base legal válida.

Recommendation: O sistema deve condicionar a emissão da ação “Utilizar” pelo titular ao aceite prévio e válido dos termos de consentimento.

Mechanism: Tela de bloqueio funcional ao iniciar o uso do aplicativo, com explicação clara do motivo e direcionamento ao fluxo de aceite dos termos.

R-4 (Turista Process Model in Turista): UCA-60

Type: Unsafe controller behavior

Cause: O titular não percebe que revogar consentimento ou solicitar bloqueio ou eliminação enquanto ainda deseja utilizar o sistema causa degradação substancial da experiência turística personalizada.

Recommendation: O sistema deve apresentar ao titular, antes de efetivar revogação de consentimento ou solicitação de bloqueio ou eliminação, informação clara sobre quais funcionalidades serão perdidas e oferecer a opção de cancelar a ação.

Mechanism: Tela intermediária de confirmação, descrevendo em linguagem simples e específica para a ação em curso as consequências funcionais da operação, com botões Cancelar e Confirmar.

R-5 (Turista Process Model in Turista): UCA-68

Type: Unsafe controller behavior

Cause: O titular acredita que pode aceitar os termos depois de já ter informado dados pessoais, sem perceber que o consentimento se torna juridicamente frágil quando o tratamento já está em curso.

Recommendation: O sistema deve garantir, no fluxo de cadastro, que o aceite dos termos preceda obrigatoriamente o fornecimento de dados pessoais, impedindo a inversão dessa ordem.

Mechanism: Wizard de cadastro com etapas sequenciais bloqueantes: aceite dos termos, depois fornecimento dos dados pessoais, e depois consentimentos específicos, sem possibilidade de avançar sem concluir a etapa anterior.

R-6 (Smartphone do Turista -> Turista): UCA-64

Type: Causes of inadequate feedback/information

Cause: O titular deixa de exercer ações que dependem do aceite dos termos, como aceitar os termos ou informar dados pessoais, porque o sistema não comunica de forma clara e tempestiva qual é o estado atual do aceite e o que é necessário fazer.

Recommendation: O Smartphone deve fornecer ao titular feedback explícito e tempestivo sobre o estado do aceite dos termos e sobre as ações habilitadas em função desse estado.

Mechanism: Indicador visual permanente do status do aceite no aplicativo, com notificação ao titular quando ações forem bloqueadas em razão do estado dos termos e com explicação direta da causa.

R-7 (Smartphone do Turista -> Turista): UCA-59

Type: Causes of inadequate feedback/information

Cause: O titular não revoga consentimentos quando deixa de desejar utilizar o sistema porque não há feedback claro do aplicativo oferecendo essa opção de forma evidente.

Recommendation: O Smartphone deve apresentar ao titular, de forma visível e acessível, a possibilidade de revogar consentimentos a qualquer momento, com indicação do estado atual de cada consentimento.

Mechanism: Painel de privacidade centralizado, acessível em poucos toques a partir da tela principal, mostrando cada consentimento ativo e oferecendo controle direto para revogação.

R-8 (Smartphone do Turista -> Turista): UCA-58

Type: Causes of inadequate feedback/information

Cause: O titular deixa de conceder consentimentos necessários ao uso pretendido porque a interface não comunica, no momento adequado, que o consentimento é condição para a funcionalidade ou serviço desejado.

Recommendation: O Smartphone deve solicitar ao titular o consentimento específico no momento em que a funcionalidade correspondente for demandada, com explicação clara do propósito do tratamento.

Mechanism: Solicitação contextual de consentimento, acionada no fluxo da funcionalidade que requer o dado, com texto explicativo direto sobre o uso.

R-9 (Smartphone do Turista Process Model in Smartphone do Turista): UCA-30

Type: Unsafe controller behavior

Cause: O Smartphone mantém ou utiliza um modelo de processo inadequado no qual ações dependentes de tratamento de dados e personalização continuam sendo emitidas mesmo quando o status de aceite dos termos está Negado. Com isso, o front-end trata como operacional um fluxo que já deveria estar bloqueado por ausência de base legal válida.

Recommendation: O Smartphone deve bloquear, no nível da lógica de interação, o envio de dados pessoais, a atualização de consentimentos e a solicitação de roteiro quando o status de aceite dos termos não estiver válido para o tratamento.

Mechanism: Regras de bloqueio funcional no front-end, com checagem obrigatória do status de aceite antes da emissão da ação ao Back-end e apresentação de mensagem clara ao usuário indicando a impossibilidade da operação naquele estado.

R-10 (Smartphone do Turista Process Model in Smartphone do Turista): UCA-33

Type: Unsafe controller behavior

Cause: O Smartphone utiliza como válida uma versão desatualizada dos termos de consentimento, permitindo registro de aceite, atualização de consentimentos específicos ou envio de dados sem garantir que o titular esteja interagindo com a versão vigente do instrumento de consentimento.

Recommendation: O Smartphone deve garantir que ações de aceite, consentimento específico e envio de dados pessoais só ocorram quando a versão local dos termos estiver sincronizada com a versão vigente disponibilizada pelo Back-end.

Mechanism: Validação prévia da versão dos termos antes da emissão da ação, com bloqueio do fluxo em caso de desatualização e redirecionamento do usuário para leitura e aceite da versão atual.

R-11 (Smartphone do Turista Process Model in Smartphone do Turista): UCA-36

Type: Unsafe controller behavior

Cause: O Smartphone não incorpora adequadamente ao seu modelo de processo o feedback do Back-end indicando Solicitação de reautenticação = Sim e, mesmo assim, continua emitindo ações sensíveis como atualização de consentimentos, envio de dados, solicitação de roteiro, encaminhamento de pedido LGPD ou registro de aceite.

Recommendation: O Smartphone deve tratar a solicitação de reautenticação como condição bloqueante para qualquer ação sensível relacionada a consentimento, dados pessoais, exercício de direitos ou acesso a funcionalidades personalizadas.

Mechanism: Interrupção obrigatória do fluxo sensível, redirecionando o titular ao processo de reautenticação antes da continuidade da operação.

R-12 (Smartphone do Turista Process Model in Smartphone do Turista): UCA-42

Type: Unsafe controller behavior

Cause: O Smartphone continua tratando como viável o envio de dados pessoais ou a solicitação de roteiro mesmo após receber do Back-end o estado RecusadoLegal, isto é, não incorpora corretamente ao modelo local a informação de que o tratamento correspondente não pode prosseguir naquele contexto.

Recommendation: O Smartphone deve interromper automaticamente o envio de dados pessoais e a solicitação de roteiro quando o status retornado pelo Back-end indicar recusa legal, informando ao titular que a ação não pode prosseguir naquele contexto.

Mechanism: Regra de bloqueio orientada pelo estado RecusadoLegal, com mensagem explicativa ao usuário e retirada das opções incompatíveis até regularização da situação.

R-13 (Smartphone do Turista Process Model in Smartphone do Turista): UCA-32

Type: Unsafe controller behavior

Cause: O Smartphone permite o registro do aceite dos termos em ordem inadequada, quando os dados pessoais já se encontram armazenados, convertendo o aceite em manifestação posterior ao início do tratamento e fragilizando a base jurídica e a evidência de conformidade

Recommendation: O Smartphone deve garantir que o registro do aceite dos termos ocorra obrigatoriamente antes do armazenamento de dados pessoais e do prosseguimento do fluxo de cadastro.

Mechanism: Fluxo sequencial e bloqueante no cadastro, no qual o aceite dos termos precede o envio e armazenamento dos dados pessoais, sem possibilidade de inversão dessa ordem.

R-14 (Smartphone do Turista Algorithm/Logic in Smartphone do Turista): UCA-45

Type: Unsafe controller behavior

Cause: A lógica de orquestração do Smartphone não emite a solicitação de roteiro mesmo quando as condições necessárias já estão satisfeitas, isto é, quando os dados pessoais estão armazenados e o status de aceite dos termos está aceito. O problema aqui não é falta de base legal, mas falha na lógica que deveria acionar a funcionalidade principal do serviço.

Recommendation: O Smartphone deve garantir que a funcionalidade de solicitação de roteiro seja disparada de forma consistente quando os pré-requisitos necessários estiverem satisfeitos, ou, alternativamente, que o titular seja informado de forma clara sobre a pendência que impede a emissão dessa ação.

Mechanism: Lógica de transição de estados no front-end que reconheça a combinação de pré-requisitos atendidos e habilite ou dispare corretamente a solicitação de roteiro, com feedback explícito em caso de impedimento.

R-15 (Smartphone do Turista Algorithm/Logic in Smartphone do Turista): UCA-47

Type: Unsafe controller behavior

Cause: O Smartphone não possui lógica adequada de recuperação, persistência e reenvio para transações críticas de conformidade, como o encaminhamento de solicitação LGPD e o registro do aceite dos termos, quando o processamento local ou o retorno do sistema indica falha técnica ou estado não operacional.

Recommendation: O Smartphone deve preservar e tratar de forma resiliente transações críticas relacionadas a consentimento e exercício de direitos, assegurando confirmação, recuperação segura e novo encaminhamento quando houver falha técnica ou processamento não concluído.

Mechanism: Manutenção da transação em estado pendente controlado, oferta de nova tentativa ao titular, feedback explícito do erro e retomada segura do fluxo sem perda da solicitação.

R-16 (Back-end (Servidor + Banco de Dados) Process Model in Back-end (Servidor + Banco de Dados)): UCA-1

Type: Unsafe controller behavior

Cause: O Back-end mantém um modelo de processo inadequado no qual a consulta a serviços externos é tratada como dispensável, mesmo quando o feedback recebido indica canal disponível e a necessidade de informação contextual ainda não foi satisfeita. Com isso, o sistema deixa de consultar clima ou localização do ponto turístico justamente quando ainda depende desses dados para sustentar a experiência personalizada.

Recommendation: O Back-end deve tratar a disponibilidade do canal externo, combinada com a necessidade de informação contextual ainda não satisfeita, como condição suficiente para emissão da consulta correspondente.

Mechanism: Regras de decisão no Back-end que reconheçam ausência ou insuficiência de dado contextual como gatilho para consulta obrigatória enquanto o serviço externo estiver disponível, evitando que o fluxo siga com lacunas de contexto.

R-17 (Back-end (Servidor + Banco de Dados) Process Model in Back-end (Servidor + Banco de Dados)): UCA-2

Type: Unsafe controller behavior

Cause: O Back-end não incorpora adequadamente ao seu modelo de processo os diferentes estados de retorno do SEFD, especialmente indisponibilidade e degradação do canal, e continua emitindo consultas como se a fonte estivesse confiável e plenamente utilizável. Isso prolonga dependência de uma fonte não operacional, aumenta a chance de resposta inconsistente e compromete a efetividade do serviço.

Recommendation: O Back-end deve adaptar ou suspender a emissão de consultas externas quando o estado da conectividade indicar indisponibilidade ou degradação incompatível com o uso confiável da resposta.

Mechanism: Política de degradação controlada do serviço, com suspensão temporária ou redução do uso da fonte externa, uso de contexto previamente validado apenas quando isso for aceitável e sinalização de incerteza para a lógica de recomendação.

R-18 (Back-end (Servidor + Banco de Dados) Algorithm/Logic in Back-end (Servidor + Banco de Dados)): UCA-7

Type: Unsafe controller behavior

Cause: A lógica de monitoramento do Back-end não trata a ausência de dados do ponto turístico como condição que exige continuidade ou reforço da coleta. Assim, o sistema interrompe ou deixa de emitir solicitações periódicas justamente quando ainda não possui informação mínima confiável para sustentar a recomendação turística.

Recommendation: O Back-end deve considerar a ausência de dados essenciais do ponto turístico como condição prioritária para manutenção do monitoramento e para retenção cautelosa desse ponto fora de rotas personalizadas até que a informação seja restabelecida.

Mechanism: Lógica de monitoramento que mantenha a solicitação periódica de informações enquanto o ponto turístico permanecer com dados ausentes ou insuficientes, combinada com regra de não recomendação plena enquanto o estado persistir.

R-19 (Back-end (Servidor + Banco de Dados) Algorithm/Logic in Back-end (Servidor + Banco de Dados)): UCA-8

Type: Unsafe controller behavior

Cause: O Back-end interrompe ou deixa de manter o monitoramento periódico do ponto turístico justamente quando o ponto se encontra em estado Restrito, Lotado ou sob Restrições locais de Segurança ou Clima. Esse comportamento é inadequado porque são exatamente esses estados que exigem reavaliação contínua para preservar utilidade, segurança operacional e qualidade da experiência.

Recommendation: O Back-end deve manter ou intensificar a atualização do estado dos pontos turísticos quando houver restrição operacional, lotação elevada ou restrições locais relevantes, de modo a permitir replanejamento contínuo da experiência.

Mechanism: Política de monitoramento persistente em situações restritivas, com reavaliação periódica do estado do ponto e possibilidade de retirada temporária do ponto das recomendações até que haja novo estado confiável.

R-20 (Equipe de Operação Process Model in Equipe de Operação): UCA-12

Type: Unsafe controller behavior

Cause: A Equipe de Operação não trata indisponibilidade de logs ou operação inoperante como gatilho obrigatório para restaurar observabilidade do sistema.

Recommendation: A operação deve tratar perda de observabilidade como condição obrigatória para restabelecer registros de auditoria e reforçar o monitoramento de incidentes.

Mechanism: Procedimento operacional que priorize restauração de logs e ativação de monitoramento quando houver logs indisponíveis ou operação inoperante.

R-21 (Equipe de Operação -> Equipe de Operação): UCA-13

Type: Unsafe controller behavior

Cause: A Equipe de Operação recebe alerta crítico, mas não prioriza endurecimento de controles, contenção do incidente e auditoria extraordinária como resposta coordenada obrigatória.

Recommendation: A operação deve tratar alertas críticos como gatilho obrigatório para resposta coordenada de segurança, contenção e auditoria.

Mechanism: Fluxo operacional de incidente com prioridade máxima, exigindo acionamento conjunto de endurecimento de controles, contenção e auditoria quando houver alerta crítico.

R-22 (Equipe de Operação Process Model in Equipe de Operação): UCA-14

Type: Unsafe controller behavior

Cause: A Equipe de Operação não interpreta falha de execução de controles como evidência de perda de efetividade dos controles de segurança e privacidade

Recommendation: A operação deve tratar falha de execução de controles como gatilho obrigatório para restaurar controles de acesso e criptografia, retenção e eliminação, anonimização e aplicação dos termos.

Mechanism: Fluxo de remediação com checklist obrigatório de restauração dos controles afetados e confirmação de reativação da conformidade operacional.

R-23 (Equipe de Operação Process Model in Equipe de Operação): UCA-15

Type: Unsafe controller behavior

Cause: A Equipe de Operação não trata atraso em solicitações LGPD como sinal de não conformidade que exige ação imediata sobre direitos do titular e controles de retenção.

Recommendation: A operação deve tratar atraso em solicitações LGPD como gatilho de priorização do atendimento ao titular e de revisão dos controles de retenção e eliminação associados ao fluxo.

Mechanism: Procedimento com priorização automática da fila LGPD e revisão dos controles de retenção e eliminação quando houver atraso no atendimento.

R-24 (Gerenciamento da empresa (Controlador, Encarregado) Process Model in Gerenciamento da empresa (Controlador, Encarregado)): UCA-23

Type: Unsafe controller behavior

Cause: O Gerenciamento não interpreta relatórios de conformidade marcados como Não_Conforme como gatilho obrigatório para revisar diretrizes LGPD, publicar termos atualizados e determinar auditorias.

Recommendation: O Gerenciamento deve tratar a não conformidade como condição obrigatória para revisão normativa, atualização dos termos e abertura de auditoria.

Mechanism: Fluxo de governança que vincule relatórios não conformes à revisão de diretrizes LGPD, publicação dos termos vigentes e determinação formal de auditoria.

R-25 (Gerenciamento da empresa (Controlador, Encarregado) -> Gerenciamento da empresa (Controlador, Encarregado)): UCA-24

Type: Unsafe controller behavior

Cause: O Gerenciamento recebe escalada de incidente grave, mas não prioriza definição de políticas de cibersegurança e procedimentos de incidentes como resposta gerencial obrigatória.

Recommendation: O Gerenciamento deve tratar a escalada de incidente grave como gatilho obrigatório para revisão e definição de políticas de cibersegurança e procedimentos de incidentes.

Mechanism: Fluxo executivo de resposta a incidente grave, com acionamento imediato para revisão de políticas e procedimentos quando houver escalada formal.

R-26 (Gerenciamento da empresa (Controlador, Encarregado) Process Model in Gerenciamento da empresa (Controlador, Encarregado)): UCA-27

Type: Unsafe controller behavior

Cause: O Gerenciamento não trata atraso nas solicitações LGPD como sinal de falha de capacidade e de governança no atendimento aos direitos do titular.

Recommendation: O Gerenciamento deve tratar atraso nas solicitações LGPD como gatilho obrigatório para priorizar o atendimento e reforçar recursos e treinamento.

Mechanism: Fluxo de escalonamento que vincule atraso nas solicitações LGPD à priorização do encaminhamento dos pedidos e à alocação de recursos e capacitação da equipe.

Link with energy

Show control structure images

No control structure images found.